



ISC 互联网安全大会



360 互联网安全中心

网络安全风险管理

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China



普华永道介绍

PwC Cyber Service

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

普华永道在全球的机构分布



ISC 互联网安全大会



360 互联网安全中心

普华永道在**158**个国家设有公司，我们为客户提供专业咨询服务，并帮助客户解决实际问题，信息安全是过去三年以来普华永道的重点投入及发展的服务领域。普华永道于1949年进入中国，已经在中国大陆**23**个城市开设了分支机构，包括北京、上海、广州、深圳、天津、重庆、成都等，共有**18,000**名员工。

专业服务

咨询

咨询服务

信息技术及安全

策略与规划

运营与流程

财务管理

公司治理、
风险及合规

人力资源

审计

税务

国家: **158**
员工: 约 **236,000**人
中国: **23**个城市

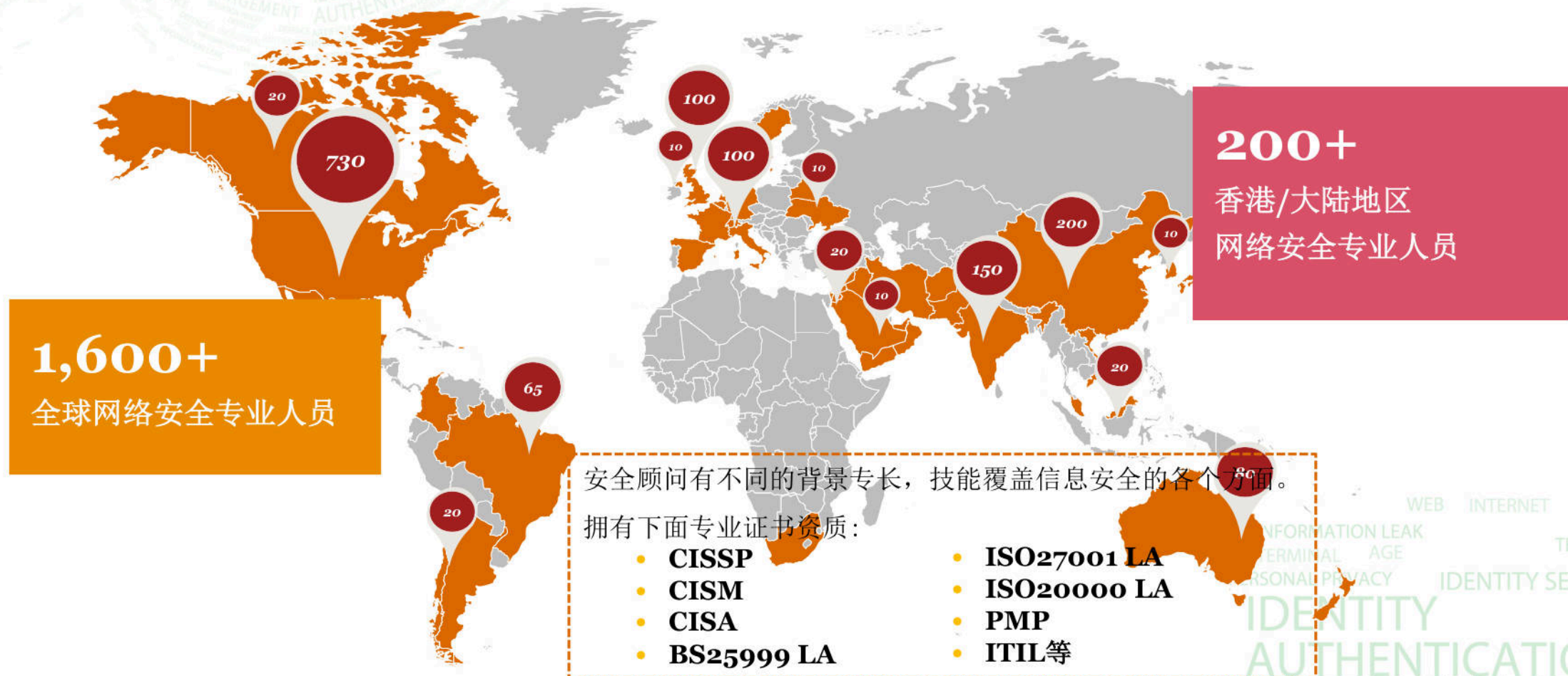
PwC Cyber Service “普华永道” 指普华永道国际网络有限的各成员机构网络，而其中每个成员均为个别及独立的法律实体。

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing · China

普华永道信息科技风险与网络安全团队



普华永道的网络安全团队在全球拥有**超过1600名**的信息科技风险和信息安全专家，我们可以帮助客户了解不断变化的信息安全挑战，适应并响应商业生态系统的固有风险，优先识别并保护企业最有价值的资产，以支持企业的经营战略。





普华永道网络安全咨询服务目录

PwC Cyber Service

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

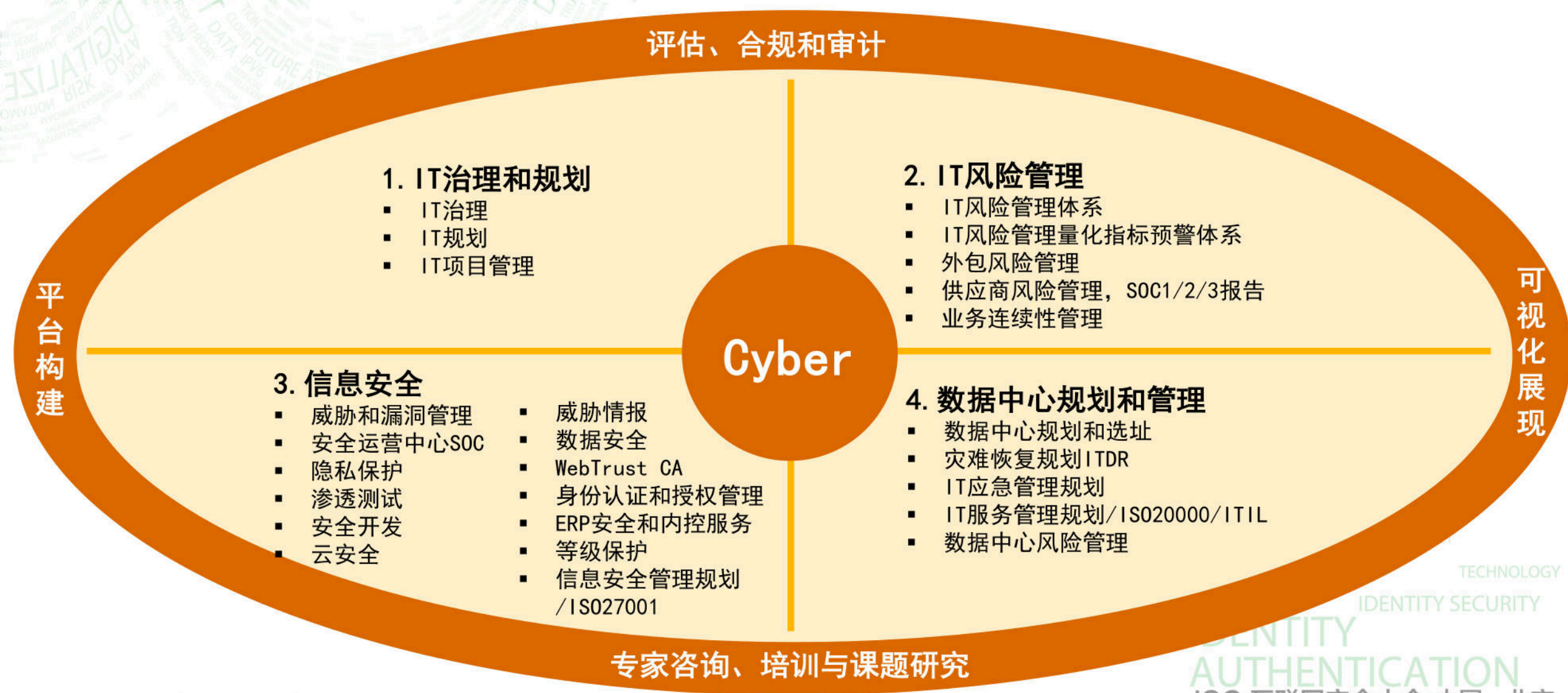
普华永道网络安全咨询服务目录



ISC 互联网安全大会



360 互联网安全中心





网络安全风险管理方法论

PwC Cyber Service

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

网络安全风险管理的必要性

网络安全态势

全球监管机构已将网络风险管理的主题置于日益严格的审查之下, 要求各个机构评估其网络安全计划的成熟程度, 管理网络风险, 并增强抵御网络攻击的能力。

战略方针

虽然各组织必须遵守每个管理机构提出的各种条例, 但它们提供的指导大体上是一致的。因此, 组织应采取基于风险的方法, 满足所有相关的法规要求, 保护其“核心业务”与敏感和关键级别相匹配。

网络风险管理的战略方法可以帮助组织:

- 全面了解网络风险、其组织和其他机构面临的威胁
- 根据相关的法规要求评估现有 IT 和网络安全计划和能力
- 将网络安全和 IT 转换计划与战略目标和关键风险相匹配
- 理解接受的风险和记录的补偿控制



重点关注内容

- 网络安全风险识别
- 开发与企业风险管理框架相一致的综合网络风险管理框架
- 通过要求批准和认证信息安全计划、政策和标准, 建立高级管理层和董事会责任制
- 增强操作要求和管控, 如加密和多因素身份验证

网络安全风险管理思路

企业现状：

随着网络威胁格局的日益复杂化和网络犯罪的加剧, 企业的经营风险也随之增加。传统的组织缺乏一种有效的网络风险管理模型。因此, 网络风险管理经常与更广泛的风险管理框架保持某种脱节。组织必须制定领先的风险管理框架, 并与组织内的其他主要利益攸关方协作, 以防止网络成为一个棘手的问题可能对整个企业造成不可挽回的损害。

解决方案：

为了建立一个强健的网络风险管理计划, 我们建议执行管理层采取以下步骤:

1. 展开现有**三道防线模型**管理网络风险, 明确建立和界定网络风险管理的角色、责任和岗位职责
2. 完善**网络风险治理**三道防线的目标运行模式
3. 在企业范围内整合网络风险**风险评估框架** 自**识别影响关键业务流程和资产的网络威胁**
4. 识别和**报告**重要的度量标准



网络安全风险管理框架



我们根据网络安全风险管理框架设计出企业执行落地方案。



主动网络安全风险管理

业务风险标识和网络威胁处理

确定关键资产

- 如果被盗、泄露或不当使用, 将给企业造成极大的困难

定义风险容忍度

- 根据业务类型为其组织定义适当的风险容忍级别

确定保护级别

- 定义资产所有权;在接受和减轻风险方面定义风险管理

初步差距分析

- 与风险管理进行差距分析, 找出潜在的弱点和潜在的暴露领域

加强持续的监测和报告工作

网络风险运营团队

- 搭建专业风险运营团队, 能够根据事件类型进行动态调整

实时风险数据分析

- 收集和分析相关威胁数据来自内部和外部来源

实时风险控制措施

- 网络风险管理小组决定要实施的适当控制, 这是保持一致性的关键。

主动响应

- 采取计划和排练的预防措施, 以缩短其持续时间并减少对组织的损害

实施威胁响应方案预演

方案规划

- 确定最大网络风险并对业务和开发方案进行调整

缓解计划

- 确定哪些过程、工具和技术可用于处理网络攻击, 以及在每个场景中的影响

制定响应计划

- 循序渐进, 尽快使业务恢复正常的计划设计

确定所需资源

- 定义所需的内容自在每个场景中处理网络攻击的影响

计划模拟和排练

网络安全风险管理量化方法



分配资产价值

列出资产清单和分配资产价值

计算暴露因子



研究每项资产，生成每个资产所有可能威胁的列表。针对列出的每个威胁，计算出暴露因子（EF）和单一损失期望（SLE）



计算单一损失期望

执行威胁分析，计算每种风险在一年内发生的可能性，也就是年发生比率（ARO）

评价年发生比率



通过计算年度损失期望（ALE），得到每个威胁可能的总损失



算出年度损失期望

研究每个威胁的对策，然后基于应用的对策，计算ARO和ALE的变化

执行对策的成本/效益分析



针对每个资产的每个威胁的每个对策执行成本/效益分析，选择每个威胁最适用的对策

分配资产价值



分配资产价值

计算暴露因子



计算单一损失期望

评价年发生比率



算出年度损失期望

执行对策的成本/效益分析



识别出需要进行风险评估的资产清单
对清单上的资产进行价值评估



计算暴露因子



分配资产价值

计算暴露因子



计算单一损失期望

评价年发生比率

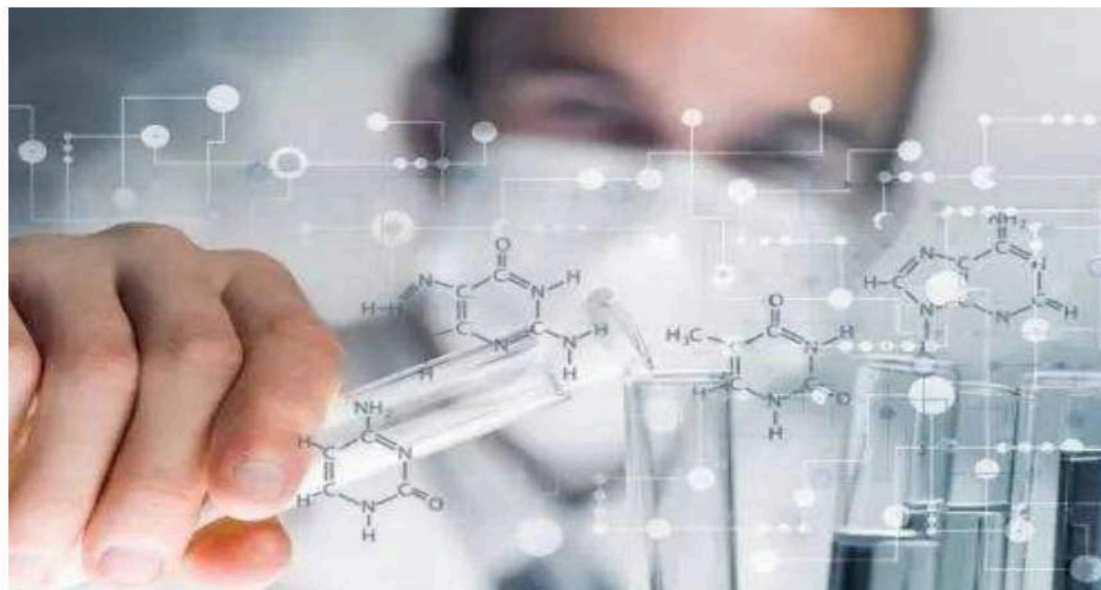


算出年度损失期望

执行对策的成本/效益分析



暴露因子(EF)代表组织的某种特定资产被已实施的风险损坏所造成损失的百分比。EF还称为潜在损失。大多数情况下,已实施的风险不会造成资产的全部损失。EF 简单地表示在发生单个风险时全部资产价值损失的预计值。EF 通常较小(对于容易被替换的资产,例如硬件),但也可以很大(对于不能替换的或专用的资产,例如产品设计或客户数据库)。EF 被表示为百分数。



计算单一损失期望



分配资产价值

计算暴露因子



计算单一损失期望

评价年发生比率



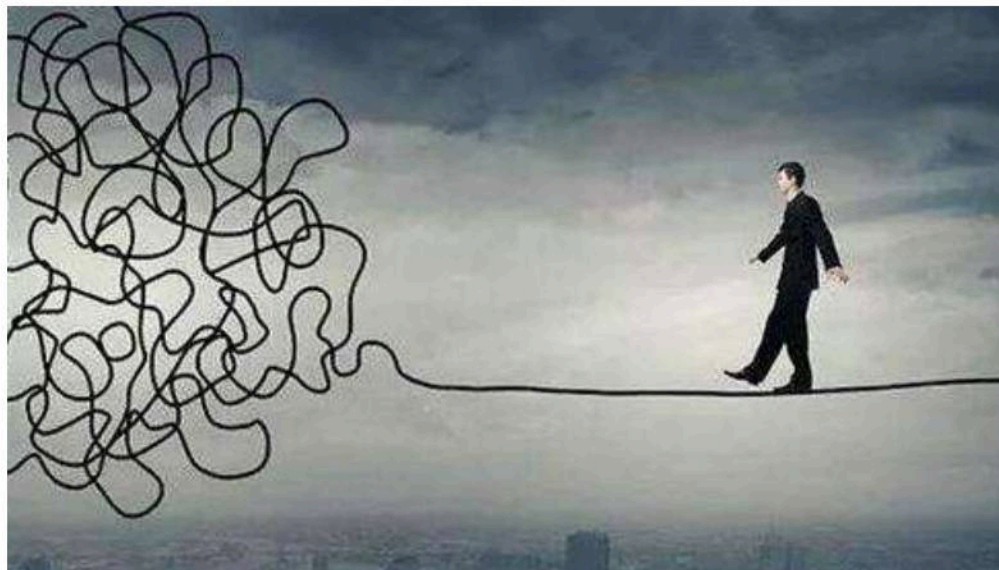
算出年度损失期望

执行对策的成本/效益分析



计算单一损失期望(SLE)时需要使用EF。单一损失期望(SLE)是与针对特定资产的单个已实施风险相关联的成本。如果某个资产被特定威胁损害，SLE 计算对组织造成的确切损失。计算SLE时，可以使用公式：

$$\text{SLE} = \text{资产价值} * \text{暴露因子}$$



评价年发生比率



分配资产价值

计算暴露因子



计算单一损失期望

评价年发生比率



算出年度损失期望

执行对策的成本/效益分析



年发生比率（ARO）指的是特定威胁或风险在一年内将会发生（也就是称为现实）的预计频率。ARO的范围为数值0.0（表示威胁或风险永远不会发生）到一个非常大的数（表示威胁或风险经常发生）。ARO的计算可能非常复杂，可以从历史记录、统计分析或猜测数据中推导出来。ARO的计算也被称为概率测定。通过将单个威胁发生的概率与引起威胁的用户个数相乘，就可以算出几个威胁或风险的ARO。



算出年度损失期望



分配资产价值

计算暴露因子



计算单一损失期望

评价年发生比率



算出年度损失期望

执行对策的成本/效益分析



年度损失期望（ALE）指的是针对某种特定的资产，所有已实施的威胁每年可能造成的损失成本。计算ALE时可以使用公式：

$$\text{ALE} = \text{单一损失期望（SLE）} * \text{年发生比率（ARO）}$$



执行对策的成本/效益分析



首先需要计算防护措施成本，评估每个特定风险的防护措施或对策。

最后计算成本/效益，用于确定某个防护措施是否能够通过较低成本真正改善安全性。

可以使用下面公式：

使用防护措施前的ALE-使用防护措施后的ALE-防护措施的年度成本=公司防护措施的价值

如果结果是负数，那么这个防护措施就不值得选择。

如果是正数，那么这个结果就是组织部署防护措施之后每年节省下来的钱。



网络安全风险管理量化案例



分配资产价值 (AV)

计算暴露因子 (EF)

$$SLE = AV * EF$$

计算单一损失期望 (SLE)

年发生比率 (ARO)

$$ALE = SLE * ARO$$

计算年度损失期望 (ALE)

执行对策的成本/效益分析

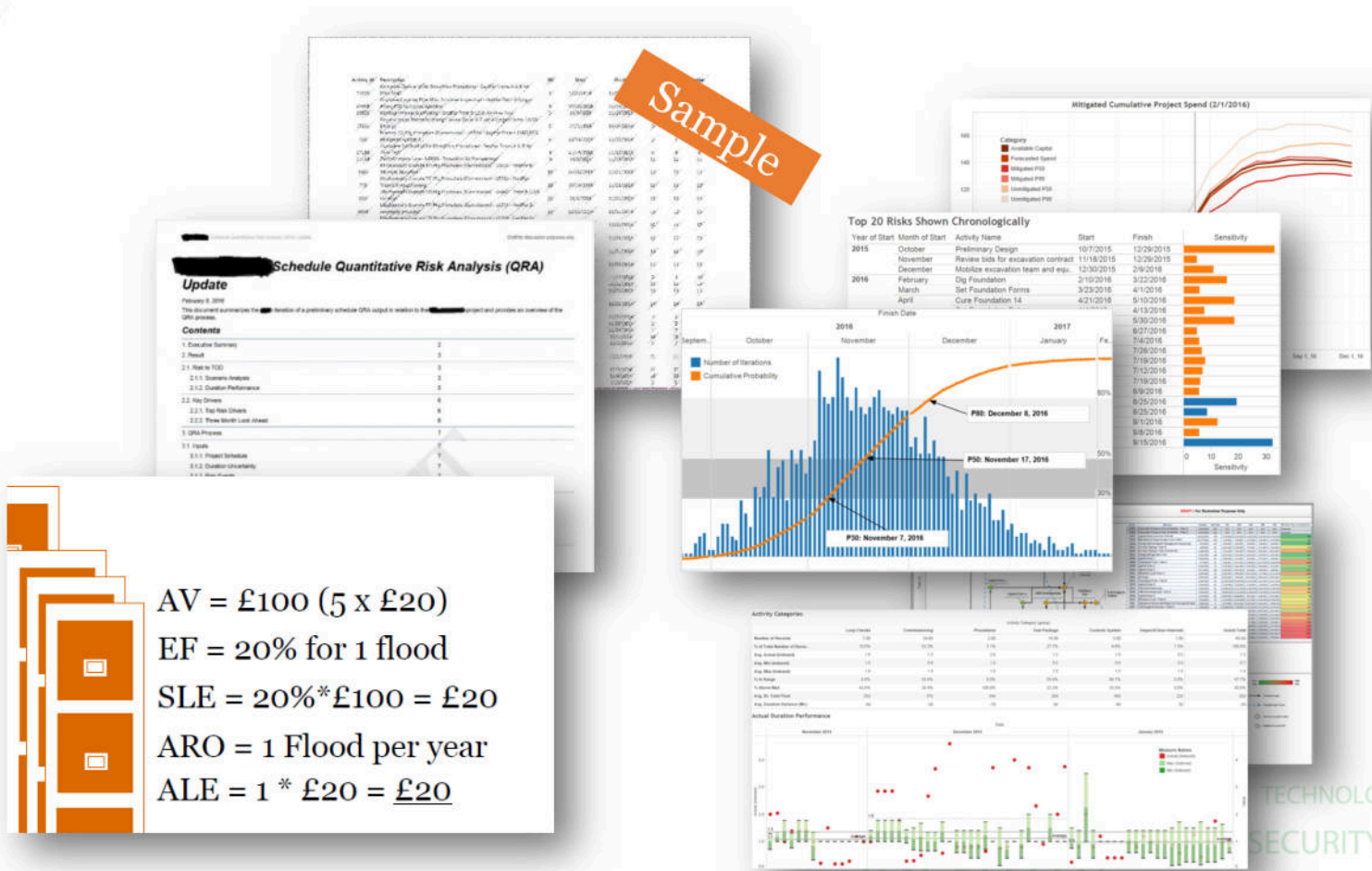
公司防护措施的价值

= 前ALE - 后ALE - 防护年度成本

PwC Cyber Service

如果结果是负数，那么这个防护措施就不值得选择。

如果是正数，那么这个结果就是组织部署防护措施之后每年节省下来的钱。



AV = £100 (5 x £20)
EF = 20% for 1 flood
SLE = 20% * £100 = £20
ARO = 1 Flood per year
ALE = 1 * £20 = £20



网络安全风险处置

PwC Cyber Service

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE TECHNOLOGY
PERSONAL PRIVACY IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing · China
INDUSTRIAL

网络安全风险处置分类



降低风险是一种消除脆弱性或组织威胁的防护措施的实施。选取最划算或性价比最好的控制对风险进行缓解、降低。

接受风险是管理层对可能采用/效益分析评估，并且确定对策的成本远远超过风险可能造成的损失的成本。

转移风险是把风险带来的损失转嫁给另外一个实体或组织。购买保险和外包就是风险转移的常见形式。

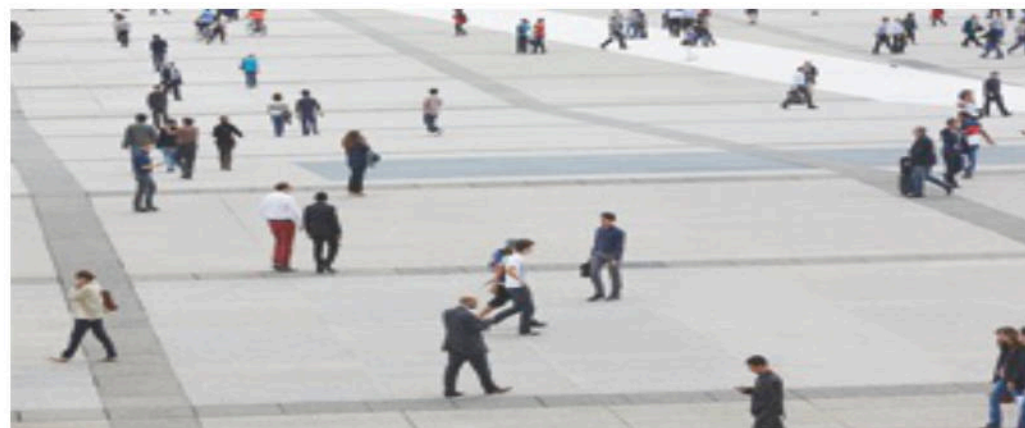
最好的风险管理策略是避免/消除所有风险。企业管理层及风险管理人员一直致力于避免/消除所有风险。通常做法是避免执行有风险的项目或流程，或通过控制授权消除所有风险。

网络安全风险处置——降低风险



降低风险是致力于通过控制措施及相关解决方案来尽量降低潜在风险发生的影响。通常情况下，我们是能接受这些控制措施不能完全消除风险带来的所有影响。

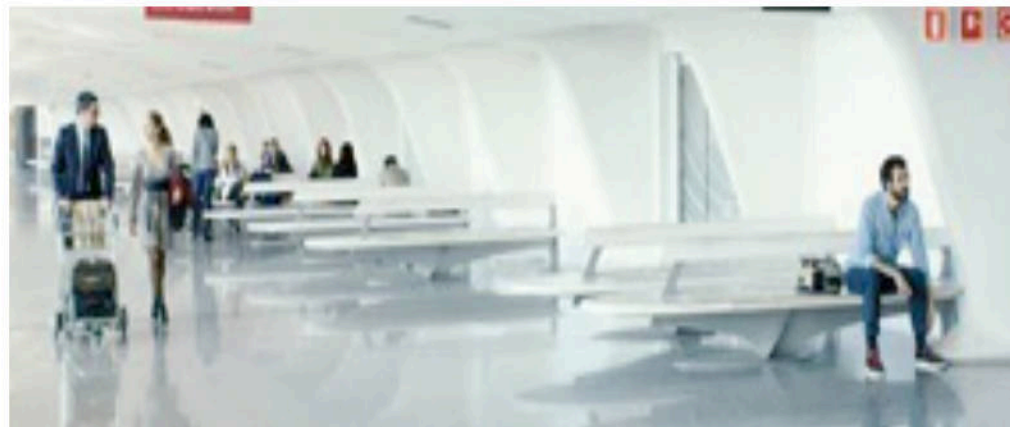
在做风险分析师，通过计算成本/效益值来确定控制成本是否是符合效益的，来最终决定对风险所做出的控制。



网络安全风险处置——接受风险



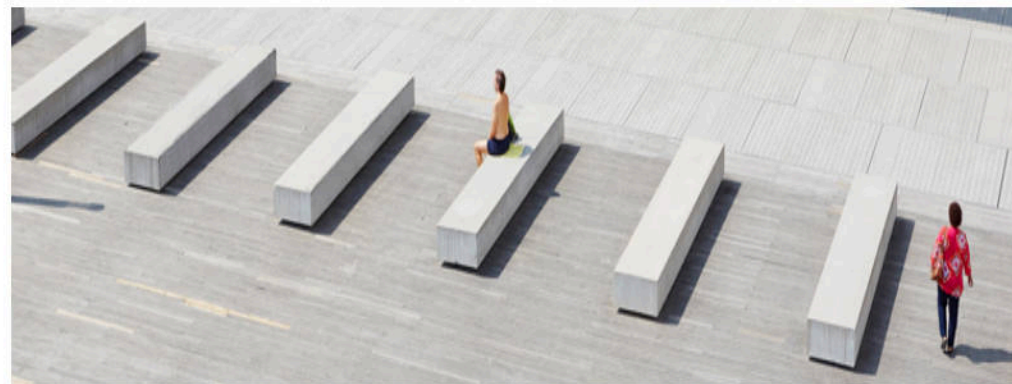
为了达到某个业务目标，在风险容忍度在接受范围之内，企业管理层及风险管理人员选择接受风险。通常，此类风险对业务影响不大，或影响虽然大，但发生频率极低，又或者控制措施成本过高。



网络安全风险处置——转移风险



转移风险是指由其他第三方来承受风险。保险是转移风险的一种最常用的形式。与另外公司签订负债合同也是转移风险的一种形式。



网络安全风险处置——避免和消除风险



通常选择避免/消除风险的项目或流程都是企业核心系统，或对业务影响较大，不能承受任何威胁及漏洞。因而企业选择不使用此系统或流程，或对此投入大量资本，避免任何风险对企业的影响。





ISC 互联网安全大会



360 互联网安全中心



冼嘉乐

网络安全与隐私咨询服务合伙人

联系方式:

电话: 010-6533-2937

传真: 010-6533-8800

电邮: samuel.sinn@cn.pwc.com

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL



ISC 互联网安全大会



360互联网安全中心

谢谢！

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing · China